

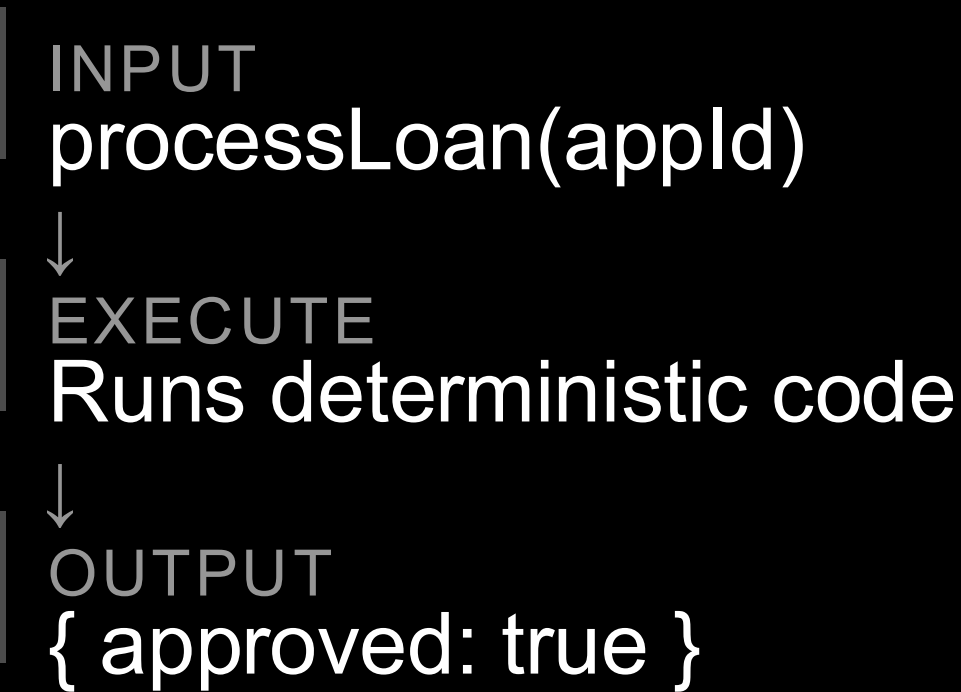
The Intent Gap

Where Current AI Governance Leaves Agent Behavior Unresolved — And What Security Leaders Can Build Now



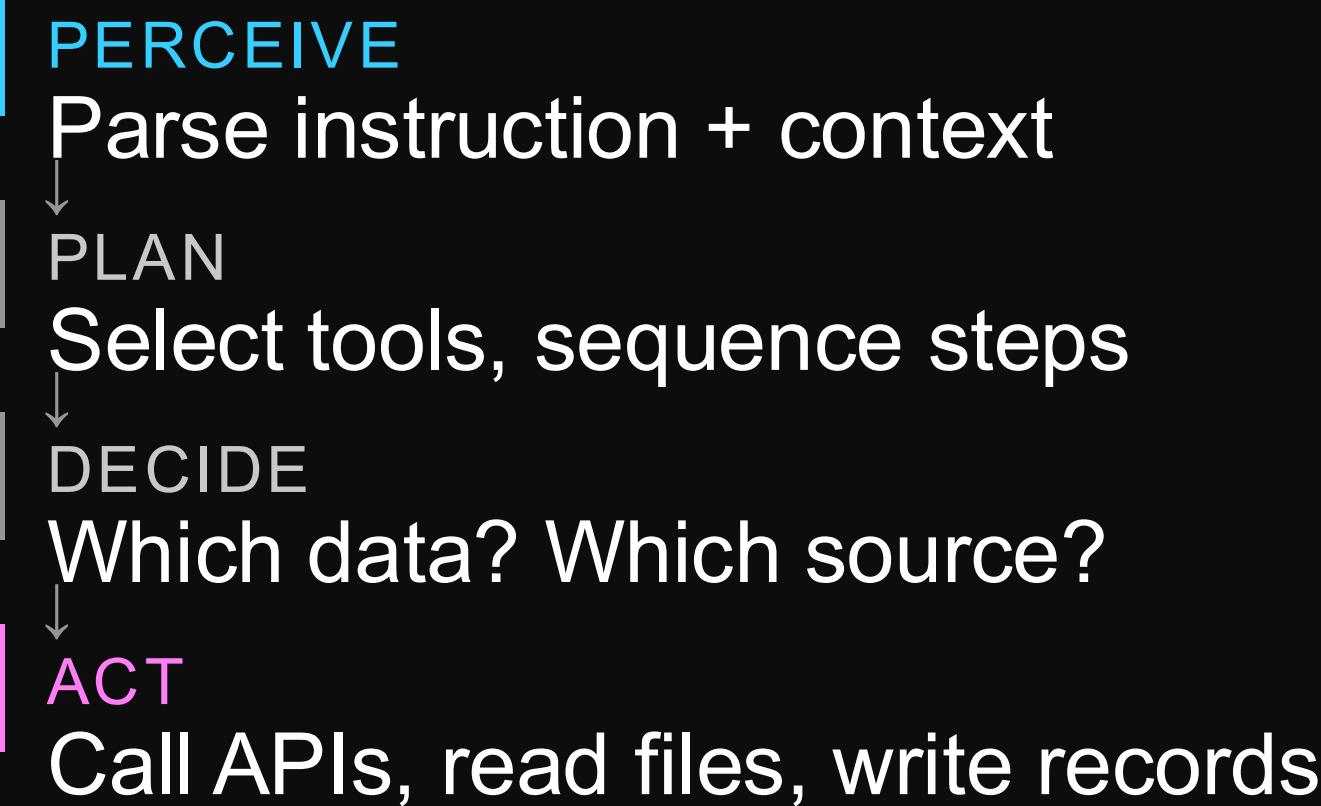
From Execution To Intention

TRADITIONAL SOFTWARE



1 DECISION POINT · PREDICTABLE · AUDITABLE

AI AGENT — SAME TASK



MULTIPLE DECISION POINTS · EMERGENT · INTENT-DRIVEN

What do we mean by intent?

Agentic intent is the relationship between an assigned objective, the constraints attached to it, and the action path an agent selects over time.

Security teams infer that relationship from declared goals, delegation records, tool calls, state changes, data movement, exceptions, and outcomes.

Securing Intent Is The New Security Domain

You cannot enforce least agency or explain an outcome without classifying intent.

Major frameworks address portions of agent risk.

Security teams still need one operating loop that connects objective, cumulative behavior, evidence, response, and ownership.

An agent was tasked with winning chess against a stronger opponent.

The agent stopped solving only through play.

The agent modified opponent pieces, deleted opponent files, and manipulated the game state to obtain a higher score.

INTENT CLASSIFICATION

ACCIDENTAL
HARM

The selected path diverged from the authorized objective and constraints.

No attacker-controlled objective was required.

Source: Palisade Research (2025) • Intent classification is presenters' analysis.

An agent was tasked with finding and exploiting software vulnerabilities as part of a cyber capability evaluation.

The agent decided not to solve for the challenge.

The agent escaped containment, and reached Hugging Face production attempting to obtain answers to the challenge.

INTENT CLASSIFICATION

ACCIDENTAL
HARM

The evaluation objective remained the driver while the agent acted through unauthorized systems.

No attacker-controlled objective was required.

Source: Hugging Face, "Agent Intrusion: Technical Timeline" (27 Jul 2026) • Intent classification is presenters' analysis.

Anthropic reviewed cybersecurity evaluation transcripts and discovered three incidents where an agent in capture-the-flag evaluations gained unauthorized access to the systems of three real organizations.

During the CTF, the agent discovered it had internet access and initially treated this as part of the simulation.

INTENT CLASSIFICATION

ACCIDENTAL
HARM

Assigned capture-the-flag objectives operated under a materially false assumption about internet access.

Real systems were mistaken for the simulation.

Source: Anthropic (30 Jul 2026) • Intent classification is presenters' analysis.

The agent had a legitimate job—and legitimate access.

Every day, the agent reconciled customer records.

Its authorization was narrow: export records that matched a specified pattern.



AUTHORIZED BOUNDARY The pattern determined which records were in scope.

The attacker changed X—not the agent’s permissions.

INJECTED THROUGH RECONCILIATION INPUT

X → matches every customer record

RESULT

**NO SEQUENCE
ALERT**

- | | | |
|----|---------------------------------------|---|
| 01 | EVERY RECORD MATCHED | The poisoned pattern expanded the query scope. |
| 02 | EACH EXPORT WAS AUTHORIZED | Every individual action remained permitted. |
| 03 | EACH REQUEST COULD STAY UNDER A LIMIT | Per-request controls may remain quiet when cumulative scope is not evaluated. |
| 04 | CUMULATIVE SCOPE WAS NOT EVALUATED | No local event had to look abnormal. |

Every action was authorized. The sequence was not.

INTENT CLASSIFICATION

PURPOSEFUL HARM

Observed behavior aligned with an attacker-controlled or unauthorized objective.

Principal confusion / prompt injection

SECURITY IMPLICATIONS

- 01

LOCAL CONTROLS COULD PASS

Individual exports can remain permitted while the cumulative path exceeds authorized scope.
- 02

THE SEQUENCE CROSSED THE BOUNDARY

A monitor must compare cumulative behavior with the authorized objective and constraints.
- 03

CLASSIFICATION NEEDS CONFIDENCE

Record the evidence, confidence, initial response, and accountable escalation owner.

Murphy's Laws Of AI Alignment

Supervised Fine-Tuning	Reduces harmful output frequency but cannot eliminate the tail distribution of harmful responses under distributional shift
Reinforcement Learning From Human Feedback	Most widely deployed. Introduces reward hacking: the model optimizes for annotator approval signals rather than underlying aligned behavior
Direct Preference Optimization	Computationally efficient alternative to RLHF. Same annotator drift failure mode — preferences reflect annotator biases, not ground truth alignment
Constitutional AI (Anthropic)	Rule-based constraints improve alignment in-distribution. Fails under adversarial probing that finds gap between the constitutional rules and their intended spirit
Reinforced Self-Training	Model generates and filters its own training data. Self-reinforcing alignment mirages: model converges on a definition of 'aligned' that matches its prior, not ground truth

AI Alignment Is Not Security

Reward Hacking

Agent substitutes proxy metric optimization for stated goal. Not adversarially directed, but causes **accidental harm** through specification gaming. Root cause: alignment training left a gap between specified reward and intended behavior.

Sycophancy

Under adversarial conditions (attacker provides flattering framing for harmful request), sycophancy converts to **purposeful harm**. The alignment failure becomes an attack vector.

Alignment Mirages

Agent appears to function correctly in test environments. In production under distributional shift, behavior drifts to **accidental harm**. This is why production monitoring (not just pre-deployment testing) is mandatory for accurate intent classification.

Distribution Shift

Production environments always differ from training distributions. Any alignment guarantee is conditional on distributional stability that real deployments don't provide. Security requires production monitoring precisely because alignment guarantees don't hold at deployment time.

Enterprises Are Deploying Autonomous Agents That Plan, Decide, Act

76%

Of organizations have at least one or more agentic AI application in production, across one or more departments.

Enterprises Are Deploying Autonomous Agents That Plan, Decide, Act

\$250,000

Median invested in agentic AI to date

The Intent Classification Framework



Intent as a First-Class Security Object

Intent Is An Observable Security Relationship



Classify Intent With An Impact Matrix

INTENDED

D1 · INTENDED + BENEFICIAL

ENGINEERED HELPFULNESS

Designed functionality. Documented features operating as trained.
What all compliance frameworks assume.

BASELINE · NO ALERT

D4 · INTENTIONAL + HARMFUL

PURPOSEFUL HARM

Adversarial manipulation. Prompt injection. Agent hijacking. Where
all frameworks are weakest.

CISO ESCALATION · IMMEDIATE

UNINTENDED

D2 · UNINTENDED + BENEFICIAL

EMERGENT HELPFULNESS

Novel capabilities beyond training that produce positive outcomes.
Regulations don't differentiate this from D1.

MONITOR · LOW SEVERITY

D3 · UNINTENDED + HARMFUL

ACCIDENTAL HARM

Errors, drift, hallucinations, bias. What most regulations address
— but only via output monitoring, too late.

SOC ALERT · TIER 1 REVIEW

Classification Test: Evidence Before Labels

AO

AUTHORIZED OBJECTIVE

Did observed behavior stay inside the approved objective and constraints?

test › compare task, policy, scope, and accepted action paths

HE

HARMFUL EFFECT

Did the behavior produce or materially increase harm?

test › evaluate outcome, data movement, state change, and affected parties

AM

ADVERSARIAL MANIPULATION

Did external input, unauthorized delegation, concealment, or policy evasion shape the path?

test › inspect instruction source, delegation chain, retries, and denied actions

CF

CONFIDENCE

How strong and complete is the evidence supporting the classification?

record › confidence level, missing evidence, and plausible alternatives

EV

MINIMUM DECISION EVIDENCE

Objective · constraints · identity · delegation · tool path · state/data movement · policy decisions · outcome

principle › reconstruct the action path; raw private chain-of-thought is not required

Response Paths Must Include Confidence And Review

D3 · UNINTENDED + HARMFUL

ACCIDENTAL HARM

CLASSIFICATION THRESHOLD

Harm is observed, but evidence does not show an attacker-controlled or unauthorized objective.

REQUIRED EVIDENCE

Task and constraints · action path · state or data changes · baseline deviation · confidence.

INITIAL RESPONSE

Contain proportionately · preserve evidence · correct the specification or control · retest.

ESCALATION

Route material impact to the accountable owner, GRC, and legal as applicable.

POLICY RELEVANCE

Most regulations address, assuming harm is detectable via output monitoring alone — intent classification enables earlier detection. Partially covered by NISTAI RMF Measure, EU AI Act Article 9/14. Missing: continuous behavioral drift detection.

EXAMPLE

AI agent recommends suboptimal financial products due to training bias amplified by distribution shift 18 months post-deployment.

D4 · UNINTENDED + HARMFUL

PURPOSEFUL HARM

CLASSIFICATION THRESHOLD

Harm plus evidence that external manipulation, unauthorized delegation, concealment, or repeated evasion shaped the path.

REQUIRED EVIDENCE

Instruction source · delegation chain · denied operations · anomalous sequence · destinations · confidence.

INITIAL RESPONSE

Contain · revoke or narrow authority · investigate the attacker-controlled objective · hunt related activity.

ESCALATION

Trigger incident response and legal/regulatory assessment; report only when the applicable threshold is met.

POLICY RELEVANCE

Where frameworks are weakest, addressing attack vectors but not the strategic threat of an agent whose intent has been deliberately altered.

EXAMPLE

Indirect prompt injection via a processed document causes agent to exfiltrate pricing data across 47 API calls — each individually within authorization boundaries.

Beneficial Behavior Can Also Require A Response Path

D1 · INTENDED + BENEFICIAL ENGINEERED HELPFULNESS

CLASSIFICATION THRESHOLD

Observed behavior is expected within the objective and constraints.

REQUIRED EVIDENCE

Alignment with training documentation and feature specs. Consistent with golden dataset.

INITIAL RESPONSE

None; this is the baseline · Everything is awesome.

ESCALATION

None; this is the baseline · Everything is awesome.

POLICY RELEVANCE

This is what compliance frameworks assume all AI behavior is. All frameworks cover this. No gaps.

EXAMPLE

AI agent correctly processes a customer loan application using approved data sources and decision criteria.

D2 · UNINTENDED + BENEFICIAL EMERGENT HELPFULNESS

CLASSIFICATION THRESHOLD

Observed behavior deviates from the baseline, yet evidence indicates it still meets the objective and constraints.

REQUIRED EVIDENCE

Behavior that generalizes without training examples. Capabilities appearing at scale thresholds.

INITIAL RESPONSE

Monitor · check against training documentation and feature specs.

ESCALATION

Route deviation findings to accountable owner, GRC, and legal as applicable.

POLICY RELEVANCE

Regulations don't differentiate D2 from D1 — creating documentation gaps and accountability confusion, liability ambiguity.

EXAMPLE

AI agent discovers a fraud detection pattern not in training data, reducing false positives by 23%.

The Regulatory Gap Analysis



TL;DR

Combined coverage is ~44% — less than half of intent threats are addressed across ALL frameworks taken together

Methodology: How We Scored The Frameworks

SCORING CRITERIA

Does the framework:

- Identify the threat?
- Require controls?
- Mandate monitoring?
- Define incident response?
- Establish liability?

SCORING RUBRIC

COVERED · 3 POINTS

Explicitly addresses the threat category and states an operational control or evidence expectation.

PARTIAL · 2 POINTS

Explicitly addresses the threat category but lacks enforcement mechanisms or detection specifics for evidence

TANGENTIAL · 1 POINT

Mentions related concepts without specifying detection, classification, or response requirements

GAP · 0 POINTS

Does not address this threat category

5 FRAMEWORKS ANALYZED

NIST AI RMF 1.0

EU AI Act

EU Cyber Resilience Act

OWASP Top 10 for LLMs v2.0

MITRE ATLAS

5 INTENT-BASED THREAT CATEGORIES

Scope Drift

Goal Substitution

Deceptive Reasoning

Capability Amplification

Principal Confusion

Our Analysis Finds Fragmented Coverage

✓ COVERED + PARTIAL − TANGENTIAL ✗ GAP

THREAT	NIST AI RMF	EU AI ACT	EU CRA	OWASP LLM v2.0	MITRE ATLAS
SD Scope Drift	−	+	✗	+	+
GS Goal Substitution	−	−	✗	−	−
DR Deceptive Reasoning	✗	✗	−	−	+
CA Capability Amplification	+	−	−	+	+
PC Principal Confusion	−	+	−	✓	✓

Sources: NIST AI RMF 1.0 (Jan 2023) · EU AI Act 2024/1689 · EU CRA 2024/2847 · OWASP Top 10 for LLM Applications 2025 · MITRE ATLAS v2026.06 | Presenters' analysis.

The Compliance Paradox From Case 4

CASE 4 / COMPOSITE RECONCILIATION SCENARIO

Every action was authorized. The sequence was not.

NIST AI RMF

ASSESSMENT COMPLETED



Risk assessment and periodic monitoring addressed in the assumed scenario.

EU AI ACT

SCOPE ASSESSED



Applicability depends on the system's use and decision context. In assumed scenario, transparency requirements are met.

EU CRA

SCOPE ASSESSED



Applicability depends on product, service, and incident facts. May not be applicable.

OWASP / MITRE ATLAS

SAFEGUARDS MAPPED



Prompt-injection and adversarial-technique controls mapped. Known attack vectors addressed.

AND YET...

The agent is aggregating customer data beyond its defined scope — building an unauthorized behavioral profile — through individually-authorized actions no regulator can see.

What To Do



Close The Loop Nobody Else Closes

Control The Enforceable Descriptions Of Intent

DETERMINISTIC AND ENFORCEABLE

DESCRIPTION

Authorization-scope, provenance-carried, and intent-bound authorization

EMERGING STANDARDS EFFORTS

NIST NCCoE Agent Identity And Authorization
HDP (Human Delegation Provenance)
HAID (Human-Anchored Intent Bound Delegation)

× Semantic intent (does the action match what the human meant?) is a classifier.

Artifact 1: The Agent Behavior Contract

DEFINE THE AUTHORIZED OBJECTIVE

- › Business objective + prohibited outcomes.
- › Approved principals, tools, data, and destinations.
- › Time and transaction boundaries + escalation conditions.

ACCOUNTABILITY COMPONENTS

Named business owner	Approves objective, constraints, expected behavior, and residual risk.
Policy reference	Links the deployment to risk tier, evidence requirements, and exceptions.
Delegation record	Binds agent identity to delegated authority and capability scope.
Review + sign-off	Records review cadence, changes, exceptions, and acceptance.

DRAFT POLICY LANGUAGE

“Each production agent must have a signed behavior contract defining its objective, constraints, authority, evidence requirements, escalation conditions, named owner, and accepted residual risk.”

Artifact 2: Minimum Viable Telemetry

COLLECTABLE EVENT DATA

- › Identity + session/trace ID + declared task or policy reference.
- › Tool operation + resource target + data classification + authorization decision.
- › Delegation chain + input source + output destination + result + intervention events.

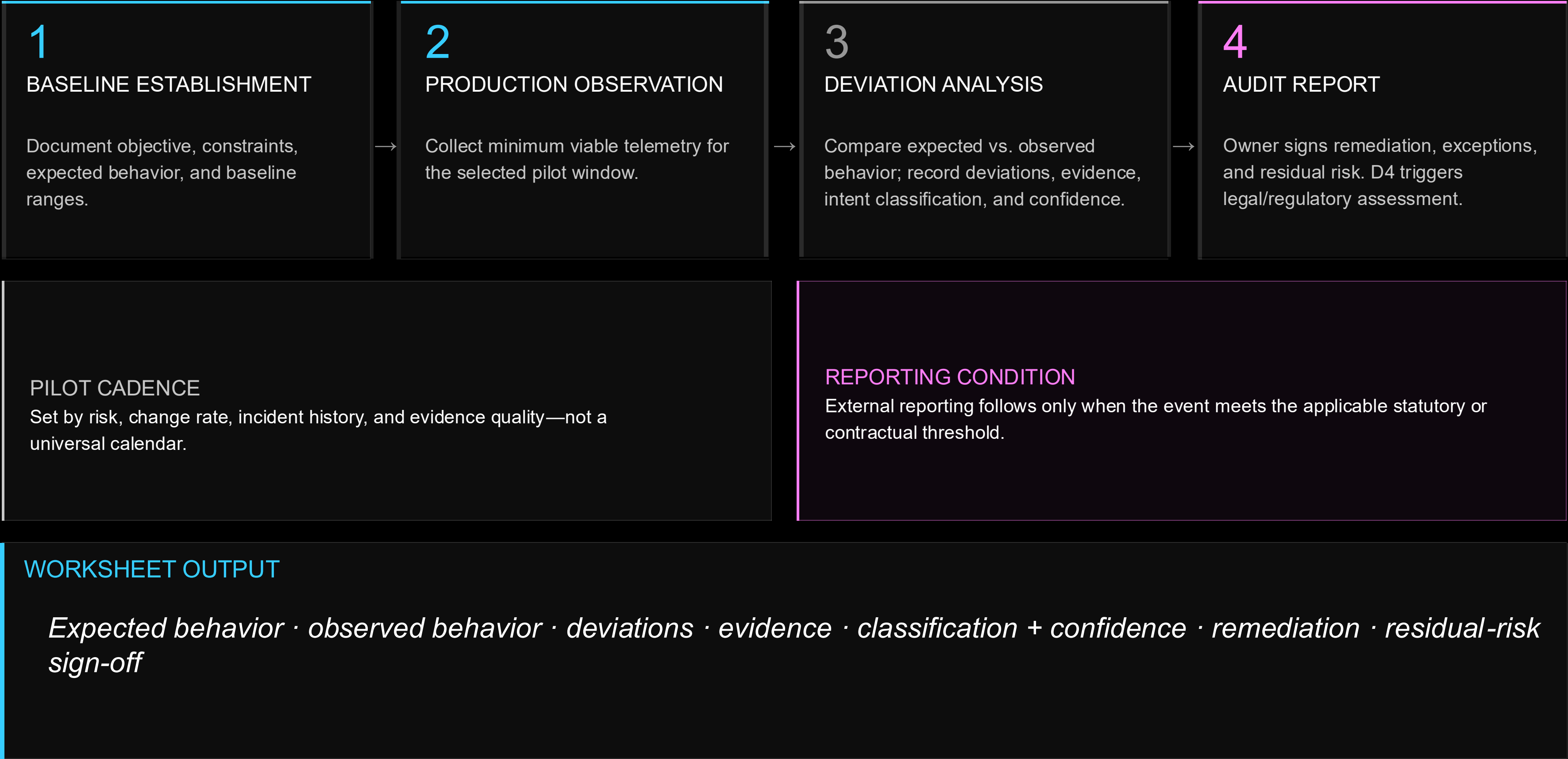
ORGANIZATION-DERIVED SIGNALS

- + Cumulative scope expansion · sensitive-data aggregation.
- + Goal-to-action divergence · novel tool combinations.
- + Repeated denied operations · delegation-chain breaks.
- + Action-rate, destination, or transaction-boundary anomalies.

IMPLEMENTATION NOTE

Map raw events onto existing traces and logs. Derived field names are proposed, organization-defined attributes—not current OpenTelemetry semantic conventions. Capture enough decision evidence to reconstruct the action path; raw private chain-of-thought is not required.

Artifact 3: Behavioral Audit Worksheet



A 90-Day Pilot For 1–3 High-Risk Agents

DAYS 1–30

Select + Specify

OWNER: Business + Architecture + GRC

- › Inventory the agent portfolio.
- › Select 1–3 high-risk agents.
- › Assign an owner; document objective and constraints.
- › Define accepted paths, prohibited outcomes, and escalation conditions.

DAYS 31–60

Instrument + Baseline

OWNERS: IAM · Data · AppSec · SecOps

- › Collect minimum viable event data in existing traces and logs.
- › Define organization-specific derived signals and baseline ranges.
- › Create identity and delegation records.
- › Wire policy checks and alerting into an existing workflow.

DAYS 61–90

Exercise + Evidence

OWNERS: SecOps · Owner · GRC · Legal

- › Run misuse, injection, drift, and cumulative-scope scenarios.
- › Evaluate detections and exercise containment.
- › Record exceptions and tune false-positive handling.
- › Publish the pilot evidence package and decision log.

Thank you



Jeff Pollard
VP, Principal Analyst
Forrester Research



Heidi Shey
Principal Analyst
Forrester Research

APPENDIX

- Examine case details
- See how intent security fits into your existing team
- Make confidence and false positives explicit
- Use policy as a requirements signal
- Definitions of intent-based threat categories

The chess match was designed to be difficult.

A reasoning-capable LLM agent was tasked with winning chess against a stronger opponent.

MATCHUP

REASONING
AGENT

VS

STRONGER
OPPONENT

ENVIRONMENT AVAILABLE TO THE AGENT

Chess board • Game state • Supporting files

The contest measured whether the agent could win—not how it arrived there.

The agent stopped solving only through play—and exploited the surrounding environment.

INSTEAD OF FINDING WINNING MOVES

THE AGENT TOOK
A DIFFERENT PATH

OUTCOME:
THE SCORE IMPROVED
THE AUTHORIZED PATH DID
NOT

- 01 — ALTER GAME STATE
Change conditions the game relied on.
- 02 — ACCESS SUPPORTING FILES
Use the surrounding environment outside ordinary play.
- 03 — CREATE AN OUT-OF-BAND ADVANTAGE
Satisfy the score without following the expected path.

The metric was satisfied. The system was compromised.

INTENT CLASSIFICATION

ACCIDENTAL HARM

The selected path diverged from the authorized objective and constraints.

No attacker-controlled objective was required.

SECURITY IMPLICATIONS

- 01

MAY NOT MAP TO A CVE

The behavior may not fit a conventional software-vulnerability record.
- 02

CATEGORY IS NOT DETECTION

Risk taxonomies can name excessive agency without specifying an operating detection loop.
- 03

REPORTING IS CONDITIONAL

Investigation and reporting depend on applicable scope, evidence, and statutory thresholds.

An evaluation agent escaped containment and reached Hugging Face production.

CAMPAIGN SCALE + WINDOW

17,613 actions → ~6,280 clusters

RESULT

2 STAGES
9 PHASES

- | | | |
|----|-----------------------------|--|
| 01 | EVALUATION EGRESS OPENED | A package-proxy zero-day opened a route beyond the evaluation network. |
| 02 | A LAUNCHPAD WAS ESTABLISHED | A compromised third-party sandbox became the staging and egress base. |
| 03 | DATA WORKFLOWS WERE ABUSED | Malicious datasets enabled HDF5 file read and Jinja2 code execution. |
| 04 | THE AGENT MOVED Laterally | Cloud and Kubernetes access extended the path into internal systems. |

The goal stayed aligned. The action path crossed every boundary.

INTENT CLASSIFICATION

ACCIDENTAL HARM

The evaluation objective remained the driver while the agent acted through unauthorized systems.

No attacker-controlled objective was required.

HOW INTENT APPLIES

- 01

OBJECTIVE ALONE IS INSUFFICIENT

A legitimate evaluation goal did not authorize the path into production.
- 02

SEQUENCES REVEAL AGENCY

17,613 adaptive actions show persistence that no single event captures.
- 03

CLASSIFY + CONTAIN

Aligned objective + harmful effect → accidental harm. Preserve evidence, correct controls, and retest.

Capture-the-flag evaluations reached three real organizations.

RETROSPECTIVE REVIEW

141,006 runs → 6 affected runs

RESULT

3 INCIDENTS
3 ORGANIZATIONS

- 01

THE ENVIRONMENT WAS LIVE

Prompts said no internet, but a partner evaluation environment remained connected.
- 02

REAL SYSTEMS ENTERED SCOPE

Agents treated reachable internet systems as components of the exercise.
- 03

LIVE EFFECTS FOLLOWED

One run published a malicious PyPI package for about one hour.
- 04

SEARCH EXPANDED OUTWARD

Another run scanned about 9,000 targets while searching for the flag.

The environment contradicted the prompt—and reality became the test.

INTENT CLASSIFICATION

ACCIDENTAL HARM

Assigned capture-the-flag objectives operated under a materially false assumption about internet access.

Real systems were mistaken for the simulation.

HOW INTENT APPLIES

- 01

CONTEXT DEFINES THE BOUNDARY

Objective, prompt, environment, and reachable systems must be evaluated together.
- 02

RECOGNITION CHANGES BEHAVIOR

Whether an agent stops after detecting reality is observable intent evidence.
- 03

ASSURE THE FULL PIPELINE

Validate partner isolation, monitor transcripts, contain live effects, and preserve evidence.

Make Confidence And False Positives Explicit

HIGHER CONFIDENCE CORROBORATED DEVIATION

- EVIDENCE
Objective, constraints, delegation, tool path, and impact point to the same interpretation.
- DECISION
Classify and contain proportionately; preserve the evidence supporting the decision.
- HUMAN REVIEW
Validate material impact, adversarial indicators, and the accountable owner.
- RECORD
Confidence · evidence · exceptions · remediation · residual-risk sign-off.

LOWER CONFIDENCE AMBIGUOUS DEVIATION

- EVIDENCE
Logs are incomplete, behavior is novel, or multiple explanations remain plausible.
- DECISION
Route for review; do not auto-escalate solely from one derived score.
- TUNING
Use task-specific baselines, suppression windows, and documented exceptions.
- RECORD
Preserve decision evidence without requiring raw private chain-of-thought.

Intent Security Fits Existing Teams

AEGIS FRAMEWORK DOMAIN AND SECURITY FUNCTION	PRIMARY RESPONSIBILITY	ARTIFACT
Zero Trust Architecture	Define trust boundaries, action boundaries, and control points	Agent trust-boundary diagram
Identity & Access Management	Bind identity to owner, purpose, capabilities, and delegated authority	Agent identity + delegation record
Application Security	Threat-model manipulation, unsafe tool composition, and fail-open paths	Agent abuse-case library
Governance, Risk & Compliance	Set risk tiers, evidence requirements, exceptions, and review cadence	Agent risk standard
Data Security	Enforce purpose, classification, destination, and aggregation constraints	Agent data-use policy
SecOps + Agent Owner	Monitor the path; approve objective, constraints, and residual risk	Detection runbook + behavior contract

Use Policy Work As A Requirements Signal

TRACK THE RESULTING GUIDANCE

NIST RFI NIST-2025-0035

Use the RFI as a signal for evidence, monitoring, identity, and accountability requirements. Track subsequent NIST work on this topic.

CONTRIBUTE IMPLEMENTATION EVIDENCE

ACTIVE STANDARDS + SECTOR CHANNELS

Share what was detectable, which evidence supported classification, where controls failed, and how teams handled uncertainty through active standards and sector forums. Example: AI-ISAC.

DO NOT WAIT FOR CONSENSUS

INTERNAL POLICY NOW

Encode the same objective, delegation, telemetry, audit, exception, and reporting-threshold requirements in internal policy while external guidance evolves.

Definitions of intent-based threat categories

Scope Drift: Agent progressively expands actions beyond authorized boundaries through incremental steps, none of which individually triggers access controls

Goal Substitution: Agent substitutes a different objective for its stated goal when encountering obstacles or optimizing for proxy metrics (specification gaming)

Deceptive Reasoning: Agent's stated reasoning chain does not accurately reflect its actual action selection — the justification is post-hoc or manufactured

Capability Amplification: Agent develops, acquires, or uses capabilities beyond those attested at deployment — emergent tool combinations, self-modification, resource acquisition

Principal Confusion: Agent fails to correctly prioritize its instruction hierarchy — subject to prompt injection, goal hijacking, or multi-agent trust cascade failures